

Written Information Security Plan (WISP)

For

CurrentFiscal LLC

This Document is for general distribution and is available to all employees.

This Document is available to Clients by request and with consent of the Firm's Data Security Coordinator.

I. OBJECTIVE

Our objective, in the development and implementation of this comprehensive Written Information Security Plan (WISP), is to create effective administrative, technical, and physical safeguards for the protection of the Personally Identifiable Information (PII) retained by **CurrentFiscal LLC**, (hereinafter known as the Firm).

+

II. PURPOSE

The purpose of the WISP is to:

1. Ensure the Security and Confidentiality of all PII retained by the Firm.
2. Protect PII against anticipated threats or hazards to the security or integrity of such information.
3. Protect against any unauthorized access to or use of PII in a manner that creates a substantial risk of Identity Theft or Fraudulent or Harmful use.
4. we can edit anything here

III. SCOPE

The Scope of the WISP related to the Firm shall be limited to the following protocols:

1. Identify reasonably foreseeable internal and external risks to the security, confidentiality, and/or integrity of any electronic, paper, or other records containing PII.
2. Assess the potential damage of these threats, taking into consideration the sensitivity of the PII.
3. Evaluate the sufficiency of existing policies, procedures, customer information systems, and other safeguards in place to control identified risks.
4. Design and implement this WISP to place safeguards to minimize those risks, consistent with the requirements of the Gramm-Leach-Bliley Act, the Federal Trade Commission Financial Privacy and Safeguards Rule, and National Institute of Standards recommendations.

5. Regular monitoring and assessment of the effectiveness of aforementioned safeguards.

IV. RESPONSIBLE OFFICIALS

CurrentFiscal LLC has designated **John Miller** to be the Data Security Coordinator (hereinafter the DSC).

The DSC is the responsible official for the Firm data security processes and will implement, supervise, and maintain the WISP. Accordingly, the DSC will be responsible for the following:

1. Implementing the WISP including all daily operational protocols
2. Identifying all the Firm's repositories of data subject to the WISP protocols and designating them as Secured Assets with Restricted Access
3. Verifying all employees have completed recurring Information Security Plan Training
4. Monitoring and testing employee compliance with the plan's policies and procedures
5. Evaluating the ability of any third-party service providers not directly involved with tax preparation and electronic transmission of tax returns to implement and maintain appropriate security measures for the PII to which we have permitted them access, and
6. Requiring third-party service providers to implement and maintain appropriate security measures that comply with this WISP
7. Reviewing the scope of the security measures in the WISP at least annually or whenever there is a material change in our business practices that affect the security or integrity of records containing PII
8. Conducting an annual training session for all owners, managers, employees, and independent contractors, including temporary and contract employees who have access to PII enumerated in the elements of the WISP. All attendees at such training sessions are required to certify their attendance at the training and their familiarity with our requirements for ensuring the protection of PII. See Employee/Contractor Acknowledgement of Understanding at the end of this document

CurrentFiscal LLC has designated **John Miller** to be the Public Information Officer (hereinafter PIO).

The PIO will be the Firm's designated public statement spokesperson. To prevent misunderstandings and hearsay, all outward-facing communications should be approved

through this person who shall be in charge of the following:

- All client communications by phone conversation or in writing
- All statements to law enforcement agencies
- All releases to news media
- All information released to business associates, neighboring businesses, and trade associations to which the Firm belongs

V. INSIDE THE FIRM RISK MITIGATION

To reduce internal risks to the security, confidentiality, and/or integrity of any retained electronic, paper, or other records containing PII, the Firm has implemented mandatory policies and procedures as follows:

PII Collection and Retention Policy

Definition: PII is personally identifiable information. This includes the name, address, SSN, banking or other information used to establish official business. This sensitive information is always at risk of being stolen.

1. We will only collect the PII of clients, customers, or employees that is necessary to accomplish our legitimate business needs, while maintaining compliance with all federal, state, or local regulations.
2. Access to records containing PII is limited to employees whose duties, relevant to their job descriptions, constitute a legitimate need to access said records, and only for job-related purposes.
3. The DSC will identify and document the locations where PII may be stored on the Company premises:
 - a. Servers, disk drives, solid-state drives, USB memory devices, removable media
 - b. Filing cabinets, securable desk drawers, contracted document retention and storage firms
 - c. PC Workstations, Laptop Computers, client portals, electronic Document Management
 - d. Online (Web-based) applications, portals, and cloud software applications such as Box
 - e. Database applications, such as Bookkeeping and Tax Software Programs

- f.** Solid-state drives, and removable or swappable drives, and USB storage media
- 4.** Designated written and electronic records containing PII shall be destroyed or deleted at the earliest opportunity consistent with business needs or legal retention requirements.
- 5.** Paper-based records shall be securely destroyed by shredding or incineration at the end of their service life.
- 6.** Electronic records shall be securely destroyed by deleting and overwriting the file directory or by reformatting the drive on which they were housed.
- 7.** Specific business record retention policies and secure data destruction policies are in an attachment to this WISP.
- 8.** We only collect PII of clients for business purposes.
- 9.** wehfuihweufwenwdjnv

Personnel Accountability Policy

- 1.** A copy of the WISP will be distributed to all current employees and to new employees on the beginning dates of their employment. It will be the employee's responsibility to acknowledge in writing, by signing the attached sheet, that he/she received a copy of the WISP and will abide by its provisions. Employees are actively encouraged to advise the DSC of any activity or operation that poses risk to the secure retention of PII. If the DSC is the source of these risks, employees should advise any other Principal or the Business Owner.
 - a.** The Firm will create and establish general Rules of Behavior and Conduct regarding policies safeguarding PII according to IRS Pub. 4557 Guidelines.
 - b.** The Firm will screen the procedures prior to granting new access to PII for existing employees.
 - c.** The Firm will conduct Background Checks on new employees who will have access to retained PII.
 - d.** The Firm may require non-disclosure agreements for employees who have access to the PII of any designated client determined to have highly sensitive data or security concerns related to their account.
- 2.** The DSC or designated authorized representative will immediately train all existing employees on the detailed provisions of the Plan. All employees will be subject to periodic reviews by the DSC to ensure compliance.

3. All employees are responsible for maintaining the privacy and integrity of the Firm's retained PII. Any paper records containing PII are to be secured appropriately when not in use. Employees may not keep files containing PII open on their desks when they are not at their desks. Any computer file stored on the company network containing PII will be password-protected and/or encrypted. Computers must be locked from access when employees are not at their desks. At the end of the workday, all files and other records containing PII will be secured by employees in a manner that is consistent with the Plan's rules for protecting the security of PII.
4. Any employee who willfully discloses PII or fails to comply with these policies will face immediate disciplinary action that includes a verbal or written warning plus other actions up to and including termination of employment.
5. Terminated employees' computer access logins and passwords will be disabled at the time of termination. Physical access to any documents or resources containing PII will be immediately discontinued. Terminated employees will be required to surrender all keys, IDs or access codes or badges, and business cards that permit access to the Firm's premises or information. Terminated employees' remote electronic access to personal information will be disabled; voicemail access, e-mail access, Internet access, Tax Software download/update access, accounts and passwords will be inactivated. The DSC or designee shall maintain a highly secured master list of all lock combinations, passwords, and keys, and will determine the need for changes to be made relevant to the terminated employee's access rights.
6. jenkjewkcewebc

PII Disclosure Policy

1. No PII will be disclosed without authenticating the receiving party and without securing written authorization from the individual whose PII is contained in such disclosure. Access is restricted for areas in which personal information is stored, including file rooms, filing cabinets, desks, and computers with access to retained PII. An escort will accompany all visitors while within any restricted area of stored PII data.
2. The Firm will take all possible measures to ensure that employees are trained to keep all paper and electronic records containing PII securely on premises at all times. When there is a need to bring records containing PII offsite, only the minimum information necessary will be checked out. Records taken offsite will be returned to the secure storage location as soon as possible. Under no circumstances will documents, electronic devices, or digital media containing PII be left unattended in an employee's car, home, or in any other potentially insecure location.

3. All security measures included in this WISP shall be reviewed annually to ensure that the policies contained in the WISP are adequate and meet all applicable federal and state regulations. Changes may be made to the WISP at any time they are warranted. When the WISP is amended, employees will be informed in writing. The DSC and principal owners of the Firm will be responsible for the review and modification of the WISP, including any security improvement recommendations from employees, security consultants, IT contractors, and regulatory sources.
4. The Firm shares Employee PII in the form of employment records, pension and insurance information, and other information required of any employer. The Firm may share the PII of our clients with the state and federal tax authorities, Tax Software Vendor, a bookkeeping service, a payroll service, a CPA firm, an Enrolled Agent, legal counsel, and/or business advisors in the normal course of business for any Tax Preparation firm. Law enforcement and governmental agencies may also have customer PII shared with them in order to protect our clients or in the event of a lawfully executed subpoena. An IT support company may occasionally see PII in the course of contracted services. Access to PII by these third-party organizations will be the minimum required to conduct business. Any third-party service provider that does require access to information must be compliant with the standards contained in this WISP at a minimum. The exceptions are tax software vendors and e-Filing transmitters; and the state and federal tax authorities, which are already compliant with laws that are stricter than this WISP requires. These additional requirements are outlined in IRS Publication 1345.

Reportable Event Policy

1. If there is a Data Security Incident that requires notifications under the provisions of regulatory laws such as The Gramm-Leach-Bliley Act, there will be a mandatory post-incident review by the DSC of the events and actions taken. The DSC will determine if any changes in operations are required to improve the security of retained PII for which the Firm is responsible. Records of and changes or amendments to the Information Security Plan will be tracked and kept on file as an addendum to this WISP.
2. The DSC is responsible for maintaining any Data Theft Liability Insurance, Cyber Theft Insurance Riders, or Legal Counsel on retainer as deemed prudent and necessary by the principal ownership of the Firm.
3. The DSC will also notify the IRS Stakeholder Liaison, and state and local Law Enforcement Authorities in the event of a Data Security Incident, coordinating all actions and responses taken by the Firm. The DSC or person designated by the

coordinator shall be the sole point of contact with any outside organization not related to Law Enforcement, such as news media, non-client inquiries by other local firms or businesses and other inquirers.

VI. OUTSIDE THE FIRM RISK MITIGATION

To combat external risks from outside the Firm network to the security, confidentiality, and/or integrity of electronic, paper, or other records containing PII, and improve - where necessary - the effectiveness of the current safeguards for limiting such risks, the Firm has implemented the following policies and procedures.

Network Protection Policy

- 1.** Firewall protection, operating system security patches, and all software products shall be up to date and installed on any computer that accesses, stores, or processes PII data on the Firm's network. This includes any Third-Party Devices connected to the network.
- 2.** All system security software, including anti-virus, anti-malware, and internet security, shall be up to date and installed on any computer that stores or processes PII data or the Firm's network.
- 3.** Secure user authentication protocols will be in place to:
 - a.** Control username ID, passwords and Two-Factor Authentication processes
 - b.** Restrict access to currently active user accounts
 - c.** Require strong passwords in a manner that conforms to accepted security standards (using upper-and lower-case letters, numbers, and special characters, eight or more characters in length)
 - d.** Change all passwords every 365 days, or under specific conditions, such as user requests or when there is evidence of a compromise
 - e.** Firm related passwords must not be used on other sites; or personal passwords used for Firm business. Firm passwords will be for access to Firm resources only and not mixed with personal passwords
- 4.** All computer systems will be continually monitored for unauthorized access or unauthorized use of PII data. Event Logging will remain enabled on all systems containing PII. Review of event logs by the DSC or IT partner will be scheduled at random intervals not to exceed 90 days.

5. The Firm will maintain a firewall between the internet and the internal private network. This firewall will be secured and maintained by the Firm's IT Service Provider. The Firewall will follow firmware/software updates per vendor recommendations for security patches. Workstations will also have a software-based firewall enabled.
6. Operating System (OS) patches and security updates will be reviewed and installed continuously. The DSC will conduct a top-down security review at least every 30 days.

Firm User Access Control Policy

1. The Firm will adhere to Federal Trade Commission 15 U.S.C § 6805. Section 314.4(c.5) regarding the implementation of multi-factor authentication.
2. The Firm will use multi-factor authentication (MFA) for remote login authentication via a cell phone text message, or an app, such as Google Authenticator or Duo, to ensure only authorized devices can gain remote access to the Firm's systems.
3. All users will have unique passwords to the computer network. The Firm will not have any shared passwords or accounts to our computer systems, internet access, software vendor for product downloads, etc. Passwords can be changed by the user without disclosure of the password to the DSC or any Firm employee at any time.
4. Passwords will be refreshed in accordance with the National Institute of Standards and Technology (NIST) guidelines. The DSC will notify employees when accelerated password reset is necessary. If a Password Utility program, such as LastPass or Password Safe, is utilized, the DSC will first confirm that:
 - a. Username and password information is stored on a secure encrypted site.
 - b. Multi-factor authentication of the user is enabled to authenticate new devices.

Electronic Exchange of PII Policy

1. It is Firm policy that PII will not be in any unprotected format, such as e-mailed in plain text, rich text, html, or other e-mail formats unless encryption or password protection is present. Passwords MUST be communicated to the receiving party via a method other than what is used to send the data; such as by phone call or SMS text message (out of stream from the data sent).

2. The Firm may use a Password Protected Portal to exchange documents containing PII upon approval of data security protocols by the DSC.
3. MS BitLocker or similar encryption will be used on interface drives, such as a USB drive, for files containing PII.

Wi-Fi Access Policy

1. Wireless access (Wi-Fi) points or nodes, if available, will use strong encryption. Firm Wi-Fi will require a password for access. If open Wi-Fi for clients is made available (guest Wi-Fi), it will be on a different network and Wi-Fi node from the Firm's Private work-related Wi-Fi.
2. All devices with wireless capability such as printers, all-in-one copiers and printers, fax machines, and smart devices such as TVs, refrigerators, and any other devices with Smart Technology will have default factory passwords changed to Firm-assigned passwords. All default passwords will be reset or the device will be disabled from wireless capability or the device will be replaced with a non-wireless capable device.

Remote Access Policy

The DSC and the Firm's IT contractor will approve use of Remote Access utilities for the entire Firm. Remote access is dangerous if not configured correctly and is the preferred tool of many hackers. Remote access using tools that encrypt both the traffic and the authentication requests (ID and Password) used will be the standard. Remote Access will not be available unless the Office is staffed and systems are monitored. Nights and Weekends are high threat periods for Remote Access Takeover data theft. Remote access will only be allowed using multi-factor Authentication (MFA) in addition to username and password authentication.

Connected Devices Policy

1. Any new devices that connect to the Internal Network will undergo a thorough security review before they are added to the network. The Firm will ensure the devices meet all security patch standards and login and password protocols before they are connected to the network.
2. "AutoRun" features for USB ports and optical drives like CD and DVD drives on network computers and connected devices will be disabled to prevent malicious

programs from self-installing on the Firm's systems.

3. The Firm or a certified third-party vendor will erase the hard drives or memory storage devices the Firm removes from the network at the end of their respective service lives. If any memory device is unable to be erased, it will be destroyed by removing its ability to be connected to any device, or circuitry will be shorted, or it will be physically rendered unable to produce any residual data still on the storage device.
4. The Firm runs approved and licensed anti-virus software, which is updated on all servers continuously. Virus and malware definition updates are also updated as they are made available. The system is tested weekly to ensure the protection is current and up to date.

Information Security Training Policy

All employees will be trained on maintaining the privacy and confidentiality of the Firm's PII. The DSC will conduct training regarding the specifics of paper record handling, electronic record handling, and Firm security procedures at least annually. All new employees will be trained before PII access is granted, and periodic reviews or refreshers will be scheduled until all employees are of the same mindset regarding Information Security. Disciplinary action may be recommended for any employee who disregards these policies.

VII. IMPLEMENTATION

Effective [date of implementation], CurrentFiscal LLC has created this Written Information Security Plan (WISP) in compliance with regulatory rulings regarding implementation of a written data security plan found in the Gramm-Leach-Bliley Act and the Federal Trade Commission Financial Privacy and Safeguards Rules.

VIII. ADDITIONAL POLICIES

Record Retention Policy

Designated retained written and electronic records containing PII will be destroyed or deleted at the earliest opportunity consistent with business needs or legal retention requirements.

It is Firm policy to retain no PII records longer than required by current regulations, practices, or standards.

1. In no case shall paper or electronic retained records containing PII be kept longer than 3 years.
2. Paper-based records shall be securely destroyed by cross-cut shredding or incineration at the end of their service life.
3. Electronic records shall be securely destroyed by deleting and overwriting the file directory or by reformatting the drive where they were housed or destroying the drive disks rendering them inoperable if they have reached the end of their service life.

Rules of Behavior and Conduct Safeguarding Client PII

Create and distribute rules of behavior that describe responsibilities and expected behavior regarding computer information systems as well as paper records and usage of taxpayer data. Have all information system users complete, sign, and comply with the rules of behavior. NISTIR 7621, Small Business Information Security: The Fundamentals, Section 4, has information regarding general rules of Behavior, such as:

- Be careful of email attachments and web links
 - Do not click on a link or open an attachment that you were not expecting. If it appears important, call the sender to verify they sent the email and ask them to describe what the attachment or link is. Before you click a link (in an email or on social media, instant messages, other webpages), hover over that link to see the actual web address it will take you to. Train employees to recognize phishing attempts and who to notify when one occurs.
- Use separate personal and business computers, mobile devices, and email accounts
 - This is especially important if other people, such as children, use personal devices. Do not conduct business or any sensitive activities (like online business banking) on a personal computer or device and do not engage in activities such as web surfing, gaming, downloading videos, etc., on business computers or devices. Do not send sensitive business information to personal email addresses.
- Do not connect personal or untrusted storage devices or hardware into computers, mobile devices, or networks.
 - Do not share USB drives or external hard drives between personal and business computers or devices. Do not connect any unknown/untrusted hardware into the system or network, and do not insert any unknown CD, DVD, or USB drive. Disable the "AutoRun" feature for the USB ports and optical drives like CD and

DVD drives on business computers to help prevent such malicious programs from installing on the systems.

- Be careful downloading software
 - Do not download software from an unknown web page. Be very careful with freeware or shareware.
- Watch out when providing personal or business information
 - Social engineering is an attempt to obtain physical or electronic access to information by manipulating people. A very common type of attack involves a person, website, or email that pretends to be something it's not. A social engineer will research a business to learn names, titles, responsibilities, and any personal information they can find; calls or sends an email with a believable but made-up story designed to convince you to give certain information.
 - Never respond to unsolicited phone calls that ask for sensitive personal or business information. Employees should notify their management whenever there is an attempt or request for sensitive business information.
 - Never give out usernames or passwords. No company should ask for this information for any reason. Also, beware of people asking what kind of operating system, brand of firewall, internet browser, or what applications are installed. This is information that can make it easier for a hacker to break into the system.
- Watch for harmful pop-ups
 - When connected to and using the Internet, do not respond to popup windows requesting that users click "OK." Use a popup blocker and only allow pop-ups on trusted websites.
- Use strong passwords
 - Good passwords consist of a random sequence of letters (upper- and lower-case), numbers, and special characters. The NIST recommends passwords be at least 12 characters long. For systems or applications that have important information, use multiple forms of identification (called "multi-factor" or "dual factor" authentication).
 - Many devices come with default administration passwords – these should be changed immediately when installing and regularly thereafter. Default passwords are easily found or known by hackers and can be used to access the device. The product manual or those who install the system should be able to show you how to change them.

- NIST guidelines recommend password reset every 365 days, or when a compromise has occurred.
- Passwords to devices and applications that deal with business information should not be re-used.
- You may want to consider using a password management application to store your passwords for you.
- Conduct online business more securely
 - Online business/commerce/banking should only be done using a secure browser connection. This will normally be indicated by a small lock visible in the lower right corner or upper left of the web browser window.
 - Erase the web browser cache, temporary internet files, cookies, and history regularly. Ensure to erase this data after using any public computer and after any online commerce or banking session. This prevents important information from being stolen if the system is compromised. This will also help the system run faster. Typically, this is done in the web browser's "privacy" or "security" menu. Review the web browser's help manual for guidance.

Security Breach Notifications and Procedures

I. Notifications

If the Data Security Coordinator determines that PII has been stolen or lost, the Firm will notify the following entities, describing the theft or loss in detail, and work with authorities to investigate the issue and to protect the victim's identity and credit.

- The [IRS Stakeholder Liaison](#) who coordinates IRS divisions and other agencies regarding a Tax Professional Office data breach.
- The state Attorney General's Office
- State tax agencies - Visit the Federal Tax Administrators' "Report a Breach" for state-by-state information
- The FBI's Internet Crime Complaint Center if it is a cyber-crime involving electronic data theft
- The Federal Trade Commission, in accordance with GLB Act provisions as outlined in the Safeguards Rule. Report security events affecting 500 or more people within 30 days of discovery through the FTC's online Safeguards Rule Security Event Reporting Form.
- Local law enforcement

- Tax software vendor (can assist with next steps after a data breach incident)
- Liability insurance carrier who may provide forensic IT services
- Legal counsel
- To the extent required by regulatory laws and good business practices, the Firm will also notify the victims of the theft so that they can protect their credit and identity. The FTC provides guidance for identity theft notifications in: [Information Compromise and the Risk of Identity Theft: Guidance for Your Business](#)

II. Procedures

The procedures of a reporting breach will be consistent for all incidents and then specific, depending on the type of potential breach reported. In all cases:

- ALL incidents must be reported to the DSC and you will be directed to fill out an incident report.
- The incident report will then be used by the DSC to conduct the right communications, notifications, and take the appropriate actions.
- The DSC will then follow IRS and FTC recommendations for appropriate action for the type of suspected problem.

See www.irs.gov and review their [Tax Security 101](#) document.

For example:

You suspect a tax return was filed using your EFIN that you did not originate:

- Go to IRS e-Services and check your EFIN activity report to see if more returns have been filed on your EFIN than you transmitted
- Check to see if you can tell if the returns in question were submitted at odd hours that are not during normal hours of operation, such as overnight or on weekends
- Were the returns transmitted on a Monday or Tuesday morning?
- Typically, a thief will remotely steal the client data over the weekend when no one is in the office to notice. They then rework the returns over the weekend and transmit them on a normal business workday just after the weekend.

IX. RESOURCE LINKS

Below are helpful links from within the WISP creation guide above and also from outside sources like the Federal Communications Commission (FCC), and the National Institute of Standards and Technology (NIST). These resources in addition to IRS and Federal

Trade Commission resources will support your efforts to create a durable Written Information Security Plan for your firm.

Federal Trade Commission

- [FTC Financial Institution How to Comply](#)
- [FTC Safeguards Rule](#)
- [FTC Data Breach Response Guide](#)
- [FTC Safeguards Rule Security Event Reporting Form](#)

National Institute of Standards

- Cybercrime & Cyber Threats to Small Business
 - [Cybercrime it's worse than we thought](#)
 - [Cybercrime existential threat small business](#)
- [NIST Computer Security Resource Center](#)
- [NIST Cybersecurity Framework examples](#)

Federal Communications Commission

- [FCC Cyber Threat Resources](#)

Internal Revenue Service

- [IRS Publication 4557](#)
- [IRS Publication 5709](#)
- IRS Publication 5280
- [IRS Publication 1345](#)
- [IRS Stakeholder Liaison](#)
- [IRS Data Theft Reporting Process](#)

X. GLOSSARY

Anti-virus software - software designed to detect and potentially eliminate viruses before damaging the system. This software can also repair or quarantine files that have already been infected by virus activity.

Attachment - a file added to an email. It could be something useful to you, or something harmful to your computer.

Authentication - confirms the correctness of the claimed identity of an individual user, machine, software component or any other entity.

Breach - unauthorized access of a computer or network, usually through the electronic gathering of login credentials of an approved user on the system.

Clear desk policy - a policy that directs all personnel to clear their desks at the end of each working day, and file everything appropriately. Desks should be cleared of all documents and papers, including the contents of the "in" and "out" trays - not simply for cleanliness, but also to ensure that sensitive papers and documents are not exposed to unauthorized persons outside of working hours.

Clear screen policy - a policy that directs all computer users to ensure that the contents of the screen are protected from prying eyes and opportunistic breaches of confidentiality. Typically, the easiest means of compliance is to use a screensaver that engages either on request or after a specified brief period.

Cybersecurity - the protection of information assets by addressing threats to information processed, stored, and transported by internetworked information systems.

Data Security Coordinator (DSC) - the firm-designated employee who will act as the chief data security officer for the firm. The DSC is responsible for all aspects of your firm's data security posture, especially as it relates to the PII of any client or employee the firm possesses in the course of normal business operations.

Data breach - an incident in which sensitive, protected, or confidential data has potentially been viewed, stolen or used by an individual unauthorized to do so. Data breaches may involve personal health information (PHI), personally identifiable information (PII), trade secrets or intellectual property.

Encryption - a data security technique used to protect information from unauthorized inspection or alteration. Information is encoded so that it appears as a meaningless string of letters and symbols during delivery or transmission. Upon receipt, the information is decoded using a decryption key.

Firewall - a hardware or software link in a network that inspects all data packets coming and going from a computer, permitting only those that are authorized to reach the other side. It is helpful in controlling external access to a computer or network.

GLBA - Gramm-Leach-Bliley Act. Administered by the Federal Trade Commission. Establishes safeguards for all privacy-controlled information through business segment Safeguards Rule enforced business practices.

Hardware firewall - a dedicated computer configured to exclusively provide firewall services between another computer or network and the internet or other external connections.

Malware - (malicious software) any computer program designed to infiltrate, damage or disable computers.

Multi-factor authentication - A security system that requires returning users to enter more than just credentials (username and password) to access an account or device, such as two-factor or three-factor authentication. The FTC Safeguards Rule requires authentication through verification of at least two of the following types of authentication factors: (1) Knowledge factors, such as password; (2) Possession factors, such as a token; or (3) Inherence factors, such as biometric characteristics.

Network - two or more computers that are grouped together to share information, software, and hardware. Can be a local office network or an internet-connection based network.

Out-of-stream - usually relates to the forwarding of a password for a file via a different mode of communication separate from the protected file. Example: A password protected file was emailed, but the password was relayed to the recipient via text message, outside of the same stream of information from the protected file.

Patch - a small security update released by a software manufacturer to fix bugs in existing programs.

Phishing email - broad term for email scams that appear legitimate for the purpose of tricking the recipient into sharing sensitive information or installing malware.

PII - Personally Identifiable Information. The name, address, SSN, banking or other information used to establish official business. Also known as Privacy-Controlled Information.

Public Information Officer (PIO) - the PIO is the single point of contact for any outward communications from the firm related to a data breach incident where PII has been exposed to an unauthorized party. This position allows the firm to communicate to affected clients, media, or local businesses and associates in a controlled manner while allowing the Data Security Coordinator freedom to work on remediation internally.

Risk analysis - a process by which frequency and magnitude of IT risk scenarios are estimated; the initial steps of risk management; analyzing the value of assets to the business, identifying threats to those assets and evaluating how vulnerable each asset is to those threats.

Security awareness - the extent to which every employee with access to confidential information understands their responsibility to protect the physical and information assets of the organization.

Service providers - any business service provider contracted with for services, such as janitorial services, IT professionals, and document destruction services employed by the firm who may come in contact with sensitive client PII.

Software firewall - an application installed on an existing operating system that adds firewall services to the existing programs and services on the system. A firewall restricts

access according to specific sets of rules to reduce or eliminate the possibility of hacking.

VPN (Virtual Private Network) - a secure remote network or Internet connection encrypting communications between a local device and a remote trusted device or service that prevents en-route interception of data.

Written Information Security Plan - a documented, structured approach identifying related activities and procedures that maintain a security awareness culture and to formulate security posture guidelines. Mandated for Tax & Accounting firms through the FTC Safeguards Rule supporting the Gramm-Leach-Bliley Act privacy law.

This plan must be finalized in the app before signatures can be collected.

Name: John Miller

Title: Principal Operating Officer / knmj

This plan must be finalized in the app before signatures can be collected.

Name: John Miller

Title: Data Security Coordinator

Plan ID: 019e9bdc-9afd-7068-ac6b-ed1029f50930